



File No.: EXP202201721

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter the claimant) filed a complaint with the Spanish Agency for Data Protection on 28/12/2021. The complaint is directed against BANCO BILBAO VIZCAYA ARGENTARIA, S.A. with NIF A48265169 (hereinafter the respondent). The reasons on which the complaint is based are as follows: the affected party states that, after losing her ID card and filing the corresponding report on 29/07/2021, a third party went to a branch of the respondent in ***LOCALIDAD.1, impersonating her identity and being provided with banking information, in addition to being given the total amount of money that was deposited in the account, without her authorization or consent; she considers that the respondent did not adopt the measures that due diligence requires by not having verified her identity (in relation to physical resemblance and signature).

She provides:

- A copy of the report filed with the police. It states that the day of the request for the statement and withdrawal was 26/07/2021 and the day of the withdrawal of funds was 29/07/2021, at branch number ***SUCURSAL.1, as indicated by information gathered from the Customer Service of the entity.
- An unsigned banking document (customer copy), dated 23/09/2021, indicating that she has received an amount of money corresponding to the sum that was withdrawn without her consent, and the commitment not to claim said amount in the future, waiving any rights or actions regarding such withdrawal.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on 11/02/2022, the aforementioned complaint was forwarded to the respondent, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 14/02/2022 as evidenced by the acknowledgment of receipt in the file.

The respondent replied on 23/02/2022 with a letter in which it did not provide any information regarding the complaint that was forwarded to it.

THIRD: On 22/03/2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/26

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following details:

The respondent replied on 04/07/2022 providing the following information:

- On 08/23/2021, the complainant requested the respondent to refund a charge on her account stating that she had not authorized it. A copy of the submitted document is provided.
- The respondent resolved to annul the fraudulent transaction made against the complainant's account balance, assuming the defrauded amount of 9,400 euros.
- On 09/22/2021, the respondent responded to the complainant indicating that it would proceed to

process the corresponding credit to her current account. A copy of the document is provided.

- On 11/25/2021, the complainant submitted a new complaint to the respondent, as evidenced by the provision of a copy of the same, requesting the refund of the amount of the fraudulent charge and an additional 20% as a consequence of "the negligent action of the branch that fails to comply with the regulation on data protection, by not verifying my identity for the purpose of providing lawful consent for the disbursement of funds and transfer of sensitive data." The complainant indicated in her writing, "this action by the financial entity constitutes a violation of my right to data protection, since it acted without due diligence, given that it did not properly validate my identity (both physical and my identifying signature) nor adopted the necessary security measures to verify my consent for the withdrawal of funds and delivery of documentation containing sensitive data."

- On 12/16/2021, the respondent informed the complainant, via email, that it would proceed to credit the charge made against her account and, regarding the request for compensation for damages, informed her that she must substantiate them in order to be evaluated. A copy of the email is provided.

- The representatives of the respondent state that the complainant did not inform the banking entity that she had lost her ID on 06/05/2021 (almost two months prior to the transaction), not following the recommendation of the Bank of Spain for such cases (they provide a copy of the aforementioned recommendation titled "Have you lost or has your ID been stolen? Inform your bank as soon as possible and report it."). The representatives of the respondent state that alerting them to the loss of the ID would have triggered the activation of the protocol that the network of offices has in these cases. For these purposes, they provide a copy of the referred protocol, which the offices must follow when a client informs them of the theft or loss of the identifying document. The protocol indicates that "in the event that the client reports the theft or loss of their identifying document, it is mandatory to add that information in the teleprocess by blocking the account (free text) including the message 'ATTENTION: document stolen/lost', restricting the operation 0001 Withdrawals in such a way as to serve as an alert for the Network."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/26

Upon request for information, the respondent replied on 30/05/2022 with the following information and documentation:

- Documentary accreditation of the procedure followed for the identification of individuals requesting in-person procedures at the offices has been requested, where all established controls regarding the accreditation of the identity of the applicants are recorded, and a copy of the instructions provided to the procedure managers in this regard. In particular, the identification procedure for the processing of information requests and cash withdrawals in person at the office has been requested.

The responding party provides a copy of the procedure (internal regulation) for cash disbursements. The internal regulation is available to the entity's employees on the intranet. They have also stated that they communicate daily any changes or updates that may affect the regulations via email, providing a copy of an email image as an example. They also declare that employees have access to a query portal, providing as an example a printout of a question regarding customer identification that includes a link to the aforementioned internal regulation.

They provide a copy of the aforementioned internal regulation, titled "Cash Disbursements Against Personal Accounts within the Scope of Universal Attention," highlighting the following aspects:

"- In the case of individuals, for signature verification, it will be sufficient to compare it with the digitized signature of the client (provided that it is available).

- Universal Attention: Clients may go to any office of the Network [...] to carry out their transactions at the Cash Desk, and we will be able to assist them without the need for it to be the office that owns the contract.

For this, it is very important to remember that to verify the client's signature, we must have the identification document digitized and the signature digitized, and in this case, it is not necessary to request verification from the owning office. [...]

- The only valid documents for proper identification are: Spanish DNI (NIF), passport, [...]
- Only originals will be valid, never photocopies, and only if they are current. Expired documents will not be accepted under any circumstances.
- Both the old and current Spanish model of driving license (also called carné de conducir) are NOT valid as identification documents. [...]

How to correctly identify:

Determine if the person presenting the document is the same as the one appearing in the photograph of the identification document.

Verify that the presented document is valid, that it is original (never a photocopy), and that it is not expired.

Observe if there may be any simple manipulation or alteration (the use of ultraviolet light is essential). Any document that presents anomalies in its format as a result of possible manipulation should raise suspicion.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 4/26

Observe the holder in person and determine if their appearance and age match the photograph and date of birth that appear on the document. Finally, it is mandatory to use the ultraviolet light lamp for the validation of the identification document.”

- A printout has been requested that certifies the details of the procedures carried out as a result of the request for information regarding the claimant's banking data and products made on 26/07/2021 at the office, as well as the information and documents that were provided to the requester, and documentation certifying the details of the specific checks on the identity of the requester that were carried out in this case. The responding party has not provided documentation regarding the procedures carried out or the information and documents that were provided to the requester, nor the documentary accreditation of the checks on the identity conducted in this specific case.

- A printout has been requested that certifies the details of the procedures carried out as a result of the refund request made on 29/07/2021 (office ***BRANCH.1), as well as documentation certifying the details of the specific checks on the identity of the requester that were carried out in this case.

Regarding the checks conducted on the identity, the representatives of the responding party indicate that “In the case being analyzed and in accordance with the aforementioned regulation, the paying office did not correctly identify the person who made the withdrawal, as the refund was carried out by a person other than the holder with documentation stolen from the client.” They provide a digitalized receipt of the withdrawal request with the signature of the requester, which consists of the name and first surname of the claimant.

They provide a screenshot of the copy of the claimant's ID with their signature (digitalized document) indicating that it is the one used for the verification prior to the cash withdrawal (they indicate that the ID is updated as a copy of the one issued due to the incident has been provided). They indicate that as a security measure, once the document fraud is detected, the office receives the following instructions: “They must digitalize the current version of their identity document; we recommend maintaining the block until it is either recovered or ceases to be valid.”

FIFTH: On 25/11/2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 6.1 of the GDPR, sanctioned in accordance with the provisions of Article 83.5.a) of the aforementioned GDPR and Article 32.1 of the GDPR, classified under Article 83.4.a) of the aforementioned GDPR.

SIXTH: Once the initiation agreement was notified, the respondent, by means of a letter dated 12/12/2022, requested an extension of the deadline to submit allegations, which was granted by the instructor of the proceedings.

On 23/12/2022, the respondent submitted a letter of allegations stating, in summary: that the accusation directed against the respondent and its legal basis is erroneous as Article 6.1 of the GDPR has not been violated, and regarding the violation of Article 32.1, the interpretation made is also

erroneous, without...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/26

to refer to the procedures established by the respondent to guarantee the validity of the cash provisions or the existing jurisprudence; the existence of a medial contest; that in the imputation of Article 32 of the GDPR, the judgment of the Supreme Court dated February 15, 2022, and the diligence displayed by the respondent are not taken into account.

Subsequently, a copy of the audio of the call made to the Customer Service by the claimant is provided.

SEVENTH: On 04/19/2023, the instructor of the procedure agreed to open a period for the practice of evidence, agreeing on the following:

- To consider as reproduced for evidentiary purposes the complaint filed by the claimant and its documentation, the documents obtained and generated by the Inspection Services that are part of the file.

- To consider as reproduced for evidentiary purposes the allegations to the initiation agreement presented by the respondent and the accompanying documentation.

- To request from the respondent:

Protocol, Procedure, or Instructions, etc., established by the entity to combat and prevent fraud or scams as in the present case, as well as the security measures or opinions for cases of fraud and fraud prevention and to proceed with a correct identification of the clientele.

Proof that such regulation along with technical or organizational measures were known by the office where the incident occurred and were known by its employees.

The respondent on 05/09/2023 responded to the practical evidence, the content of which is in the file.

EIGHTH: On 06/29/2023, a Proposal for Resolution was issued stating that the Director of the Spanish Agency for Data Protection should sanction the respondent for violation of Article 6.1 and 32.1 of the GDPR, classified in Article 83.5.a) and Article 83.4.a) of the aforementioned GDPR, with a fine of €50,000 (fifty thousand euros) and €20,000 (twenty thousand euros), respectively.

The aforementioned Proposal was notified to the respondent on 07/03/2023, responding to the allegations made in the written submission to the initiation agreement.

After the legally established period elapsed, the respondent submitted a written statement of allegations on 07/25/2023 reiterating the arguments made throughout the procedure: that there was no violation of Articles 6.1 and 32.1 of the GDPR and the existence of a medial contest of violations, requesting the filing of the procedure.

NINTH: From the actions taken in the present procedure, the following have been established,

PROVEN FACTS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/26

FIRST. On 12/10/2020, a written statement from the claimant was received at the AEPD stating that she had been a victim of identity theft; after losing her ID and filing the corresponding complaint, a third party went to a branch of her banking entity and was given all the money that was deposited in her account, without her authorization or consent, considering that the respondent entity did not take the appropriate measures by not verifying her identity reliably.

SECOND. The claimant has provided a copy of the complaint filed on 08/16/2021 with the police, report number ***DILIGENCIA.1 at Uscorts. In it, the claimant states:

“(…)

That she has been on vacation, outside of Europe...

That, upon returning to national territory, she opened the mobile application of her banking entity and noticed that a withdrawal had been made, in person at the counter, of €9,400, without her consent or authorization.

That the complainant states that this amount of money was withdrawn from the BBVA entity, located in LOCALIDAD.2 (**LOCALIDAD.1), specifically from the office **SUCURSAL.1.

That Ms. A.A.A. contacted Customer Service of her banking entity and they informed her that new documentation had been uploaded to her personal profile, of which she has not made or has any knowledge.

That customer service provided her with data related to the event, such as the day the statement and withdrawal were requested and the day the money was withdrawn.

That the day of the request was 07/26/2021 and the day the money was withdrawn was 07/29/2021, both done in person at the banking entity in LOCALIDAD.2.

That the complainant does not know who, how, and in what manner they were able to access her personal data and, especially, how they were able to withdraw money, in person, from the banking entity if they supposedly carry out identity verification.

(...)"

THIRD. The claimant provides a copy of the complaint made in Italy, at the Venice-San Marco station, regarding the loss of her ID.

FOURTH. The respondent has provided a written statement signed by the claimant, undated, in which she requests the return of the amount stolen from her account.

FIFTH. The respondent in a written statement dated 05/30/2022 has stated that: "In the case being analyzed and in accordance with the aforementioned regulation, the paying office did not correctly identify the person who made the withdrawal, as the withdrawal was carried out by a person different from the account holder with the documentation stolen from the client," and the proof of the withdrawal request is provided, whose signature does not match the one on the claimant's ID.

It also stated that "...it has resolved to annul the fraudulent withdrawal made against the balance of the claimant's current account, thus BBVA assumes the defrauded amount of €9,400..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/26

SIXTH. It is recorded that a document dated 23/08/2021 was submitted in response to the claimant's request for the refund of the amount of the fraudulent charge on their account, in which it is indicated that: "The request is being processed with the reference number **REFERENCIA.1, indicating this number you may make any inquiries regarding this matter," and the response provided by the respondent on 22/09/2021 stating that: "We have received the document you submitted, dated 23 August 2021. Your reference number is **REFERENCIA.1.

The object of the claim, as stated in your communication, is to request the return of the money (€9,400) that was taken from one of the BBVA offices, without your consent or authorization, as explained in the complaint attached to your document.

In this regard, after reviewing the facts you describe and the documentation collected in this regard, we inform you that we have forwarded this matter to the appropriate departments of our entity that are responsible for analyzing and resolving the facts detailed in your document.

Once your case has been reviewed and all necessary checks have been carried out, we are informed that your request has been favorably addressed, so in the coming days, we will proceed to process the payment into your account of the amount subject to your claim.

(...)"

SEVENTH. As noted in the fifth fact, a document from BBVA Cash Disbursement, dated 29/07/2021, against Account: ES00 0000 0000 0000 0000 0000, belonging to the claimant, is recorded, in which it states: I have received from Banco Bilbao Vizcaya Argentaria S.A., charged to the indicated account, the amount of: €9,400.00.

At the bottom of the document appears the signature of the intervenor, whose signature does not

match that of the claimant.

EIGHTH. It is recorded that the claimant sent the respondent a new claim on 25/11/2021 requesting, along with the refund of the amount of the fraudulent charge, an additional 20% as a consequence of “the negligent action of the branch that fails to comply with the regulation on data protection, by not verifying my identity for the purpose of providing lawful consent for the delivery of funds and transfer of sensitive data.”

The respondent replied on 12/12/2021 that: “...Regarding your request for compensation for damages caused, we inform you that it is the claimant's burden to prove the alleged damages, through the appropriate documentation, which substantiates the damage and the causal relationship with the action or omission of the Bank. It must be taken into account that to assess the damages caused, it is not sufficient that they have been effectively caused, but it is also necessary that they have resulted in damage or damages and that these can be proven by objective means and are quantifiable on objective bases as well. The substantiation of these aspects corresponds to the person who alleges them and, in many cases, requires the development of a evidentiary phase that can only be carried out in a judicial proceeding...”

NINTH. It is recorded that the respondent provided a response on 21/02/2022 stating that: “We are addressing you regarding the new document you sent to this...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/26

entity, through the Spanish Agency for Data Protection, regarding the amount withdrawn from your account at a BBVA branch without your consent and the violation of your right to data protection.

In this regard, we inform you that after reanalyzing the facts subject to your complaint, the specific conditions of the obligations assumed by the parties, and their particular circumstances, this Entity considers the response provided to complaint ***RECLAMACIÓN.1, a copy of which we attach, to be adequate, and we reaffirm it.

Furthermore, we have confirmed that on December 16, 2022, the amount you claimed, totaling €9,400, was credited to your account.

However, as we informed you in our previous response, if you do not agree with this resolution, you have the right to appeal to the Department of Conduct of Entities of the Bank of Spain from the receipt of this letter...

TENTH. The claimant provides a copy of a document issued by BBVA, dated 09/23/2021, unsigned, indicating that the claimant has been credited the amount of €9,400, committing to not claim any amount from BBVA in the future, waiving any action.

ELEVENTH. The respondent has provided a copy of the audio of the call made to the customer service of the respondent regarding the withdrawal of funds from their account.

TWELFTH. The respondent has provided documents related to Cash Withdrawals against personal accounts within the scope of universal attention, which include the instructions regulating withdrawals against checking accounts, credit accounts, and savings books, as well as the issuance of bank checks and cash transfers; for the prevention of Fraud and Scam, which includes instructions for fraud prevention as well as specific procedures according to the type of fraud, security opinions, and other considerations regarding fraud and the criteria and guidelines for the Identification of Customers.

THIRTEENTH. The respondent has provided documents regarding Fraud from cash withdrawals with stolen IDs and false identification documents, describing the modus operandi and how to act in case of identifying such operations.

FOURTEENTH. The respondent has provided emails dated 01/25/2021 sent to the offices, including the one where the incident occurred, subject: Security Alert 0121-January-2021 Fraud from cash withdrawals with stolen IDs (important dissemination to all colleagues in the office).

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

The reported facts materialize in the identity theft of the claimant by a third party who went to a branch of the respondent entity, being provided with banking information and the delivery of the total amount of money deposited in the account without their authorization or consent, considering that the regulations on the protection of personal data have been violated.

Article 58 of the GDPR, Powers, states:

"2. Each supervisory authority shall have all of the following corrective powers:

(...)

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case;

(...)"

First, Article 6, Lawfulness of processing, of the GDPR in its paragraph 1, establishes that:

"1. Processing shall be lawful only if at least one of the following conditions is met:

a) the data subject has given consent to the processing of their personal data for one or more specific purposes;

b) processing is necessary for the performance of a contract to which the data subject is a party or for the implementation of pre-contractual measures at the request of the data subject;

c) processing is necessary for compliance with a legal obligation to which the controller is subject;

d) processing is necessary to protect the vital interests of the data subject or of another natural person;

e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/26

f) the processing is necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that these interests do not prevail over the interests or the fundamental rights and freedoms of the data subject requiring the protection of personal data, particularly when the data subject is a child.

The provisions of letter f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions."

On the other hand, Article 4 of the GDPR, Definitions, in its paragraphs 1, 2, and 11, states that:

"1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

"2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of making available, alignment or combination, restriction, erasure, or

destruction;

"11) 'consent of the data subject': any freely given, specific, informed, and unambiguous indication of the data subject's wishes by which they, by a statement or by a clear affirmative action, signify agreement to the processing of personal data relating to them."

III

1. The processing of data requires the existence of a legal basis that legitimizes it.

In accordance with Article 6.1 of the GDPR, in addition to consent, there are other possible bases that legitimize the processing of data without the need for the authorization of the data subject, particularly when it is necessary for the performance of a contract to which the data subject is a party or for the implementation, at their request, of pre-contractual measures, or when it is necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that these interests do not prevail over the interests or the fundamental rights and freedoms of the data subject requiring the protection of such data. Processing is also considered lawful when it is necessary for compliance with a legal obligation to which the data controller is subject, to protect vital interests of the data subject or of another natural person, or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/26

In accordance with the provisions of Article 6.1, there is no evidence of any legitimate basis as contemplated in the aforementioned provision for the processing of the claimant's data, whose identity was impersonated to empty the account of which she was the holder, without the respondent exercising the necessary diligence to prevent incidents such as the one that led to the claim and consequently to the present procedure.

2. In the present case, the claimant's data was used to carry out a transaction, the withdrawal of cash from an account, by a third party who was not the account holder but an impersonator of the claimant's identity. Although, in general terms, the credit institution has the legitimacy to process the affected party's data by virtue of the contract signed between both parties, for this specific transaction it did not have such legitimacy since the person using the data was a stranger to the contractual relationship and should have verified the photograph and signature on the document presented to them, ensuring that the appearance of the document holder and the person in front of them matched.

The claimant has stated that she does not know who the person was that went to her bank branch, being handed the entirety of the money deposited in her account, without her authorization or consent and without taking the corresponding measures by not reliably verifying their identity.

It should be noted that, as stated in the proven facts, the respondent himself has indicated in his response to the information request from the Agency dated 04/07/2021 that "In the case being analyzed and in accordance with the aforementioned regulation, the paying office did not correctly identify the person who made the withdrawal, as the refund was carried out by a person different from the holder with documentation stolen from the client."

Furthermore, the respondent has provided the receipt for the withdrawal request, whose signature does not match that on the claimant's ID.

Additionally, he states that "...it has been resolved to annul the fraudulent transaction made against the balance of the claimant's current account, thus BBVA assumes the defrauded amount of 9,400 euros..." (the underlined portions correspond to the AEPD).

Therefore, it is not, as the respondent claims in the response to the Proposal for Resolution, a case of an insurmountable error in identifying the holder of the claimant's ID, but rather a serious lack of negligence that could have been overcome had the established procedures and protocols been correctly followed, properly comparing and verifying both the photograph and the signature on the document presented alongside the Cash Withdrawal document, which does not align with what the respondent himself indicated regarding the incorrect identification of the person who made the withdrawal.

On the other hand, it is unnecessary to point out that the state of the art might allow for the adoption of more effective identification measures such as biometric ones, but these are considered unlawful by the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/26

In accordance with the above, it is estimated that the respondent would be responsible for the infringement of the GDPR: the violation of Article 6.1, an infringement classified under Article 83.5.a).

IV

Secondly, Article 32 of the GDPR "Security of processing" establishes that:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular account shall be taken of the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

The violation of Article 32 of the GDPR is classified under Article 83.4.a) of the aforementioned GDPR in the following terms:

"4. Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, whichever is higher:

- a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.
(...)"

For its part, the LOPDGDD in its Article 73, for the purposes of prescription, classifies as "Serious Violations":

According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: violations that constitute a substantial breach of the articles mentioned therein and, in particular, the following:

(...)

- g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679."

(...)

V

- 1. The GDPR defines personal data security breaches as "all breaches of security that result in the

accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

The documentation in the file evidences that the respondent has violated Article 32 of the GDPR by failing to implement and utilize appropriate technical and organizational measures to ensure a level of security appropriate to the risk in this processing. This is independent of the fact that, in this specific case, a third party was also able to impersonate the claimant by being provided not only with the entirety of the money in the account but also information related to it.

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the likelihood and severity of risks to the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a process of verification (which is not an audit), assessment, and evaluation of the effectiveness of the measures. In any case, when assessing the appropriateness of the level of security, particular account shall be taken of the risks presented by the processing of data, such as

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/26

as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damages.

In this same sense, Recital 83 of the GDPR states:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial damages.”

2. In the present case, as stated in the facts and within the framework of the investigation file, the AEPD forwarded the complaint filed to the respondent for analysis, requesting the provision of information related to the reported incident, without initially providing any information regarding the forwarded complaint.

However, as noted in the previous foundation, in a document dated 07/04/2021, the respondent acknowledged that in this specific case “the paying office did not correctly identify the person who made the withdrawal, as the refund was carried out by a person different from the account holder with the documentation stolen from the client,” having refunded the amount withdrawn to the claimant, assuming the loss.

The respondent provides the proof of the withdrawal request in which the signature of the person making the withdrawal appears, as well as the scanned copy of the ID and signature (digitized) that must be verified prior to the cash withdrawal.

The signature that appears on the proof of the withdrawal request does not correspond to or seem to match the one on the ID.

3. As stated in the proven facts, the respondent submitted the document "Cash Withdrawals Against Personal Accounts within the Scope of Universal Attention" in which the instructions regulating withdrawals against current accounts, credit accounts, and savings books are collected, both at the office where the account is held and at a different office.

In point 2, Risk Aspects, it states:

"The main risk aspect in a withdrawal is the incorrect identification of the person who is going to make the withdrawal.

The identification process is regulated in standard 80.00.116 "Customer Identification":

- If the person is not properly identified (whether or not they are a customer), when this identification is mandatory, the operation they request may and must be denied.

This is permitted by Law 10/2010 and various judgments that speak of the "distrust guideline" that those in charge of third-party assets, such as employees of financial entities, must follow.

It then states in point 3.2, Control Measures for Identifying Documents, the following:

"How to correctly identify:

Determine if the person carrying the document is the same as the one appearing in the photograph of the identifying document.

Verify that the document presented is valid, that it is original (never a photocopy), and that it is not expired.

Observe if there could be any simple manipulation or alteration (the use of ultraviolet light is essential). Any document that presents anomalies in its format as a consequence of possible manipulation should raise suspicion.

Physically observe the holder themselves and determine if their appearance and age match those in the photograph and the date of birth appearing on the document.

Finally, it is mandatory to use the ultraviolet light lamp for the validation of the identifying document."

Also, in the document Prevention of Fraud and Scam, it contains instructions to avoid this type of crime. In this regard, it outlines the procedure for correctly identifying the customer, valid documents, how to verify the person and the document, etc., in a manner similar to the previous one.

This document already states that "The correct identification of the customer, whether it is an individual or a representative of a legal entity, is fundamental for the early prevention of fraud."

It also indicates that:

"The only valid documents for correct identification are:

* National Identity Document.

* Passport.

* Foreign Identification Number (NIE), with its various types of Cards (residence, asylum, student, etc.).

* National identifying document from a European Union country with a photograph.

Only originals will be valid, never photocopies, and only if they are current. Expired documents will not be accepted under any circumstances."

And that:

"In terms of carrying out a correct identification, the first step is to determine if the person carrying the document is the same as the one appearing in the photograph of the identifying document, then we will verify that the document...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/26

The presented document is valid. That is to say, it must be among those that the bank considers appropriate for proper identification, it must be original (never a photocopy), and it must not be expired. The second point is to observe whether there could be any simple manipulation. For this, a superficial glance at the ID is not enough. It must be examined in detail.

Therefore, in accordance with this last document and the established protocol for cash withdrawals, the person requesting the transaction, whether or not they are a client of the entity, must properly

identify themselves, and if not, the transaction must be denied.

Furthermore, that person must provide a valid identification document, which must be the original, not a photocopy, not manipulated, not expired, and not presenting any anomalies, verifying that the appearance of the holder and the person in front of them match, that is, confirming through the document that they are indeed the person they claim to be.

However, in the present case, it does not appear that the actions taken by the employee at the office, as confirmed by the respondent, reliably verified in accordance with the instructions outlined in both the document "Cash Withdrawals Against Personal Accounts within the Scope of Universal Attention" and in the Fraud and Scam Prevention document, the identity of the person making the withdrawal, since the amount handed over, which caused the account to be emptied, was provided to someone who was not the account holder, violating the corresponding measures.

4. Furthermore, regarding the cash withdrawal, on 29/07/2021, a third party went to the office of the respondent located at ***ADDRESS.1, in ***TOWN.2 (***TOWN.1) requesting the withdrawal of funds from the claimant's account, thereby failing to comply with the established identification protocol for cash withdrawals.

The document provided by the respondent contains the name and surname of the claimant and a signature that bears no resemblance to that on the copy of the ID, despite what the respondent has stated to the contrary.

But what is paradoxical is that the copy of the ID that was presented at that moment to carry out the transaction was digitized by the same person who provided the money to the usurper, that is, the ID presented at the time of the withdrawal was scanned and recorded in the entity's database, as was informed to the claimant by the Customer Service on their call dated 04/08/2021, according to the recording provided.

Therefore, what the preceding evidence shows is that on the same day of the cash delivery, the employee of the branch digitized the ID used in the transaction in the entity's systems, without realizing that the person in front of them was not who they claimed to be, thus failing to guarantee the security of the data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/26

In its allegations to the Proposal, the respondent insists on stating that the necessary measures were adopted to verify the identity of the applicant, concluding that the person who came to the bank office was indeed who they claimed to be and corresponded with the claimant, whose document was provided. This is surprising in light of the facts established in the proceedings: the signature did not match that on the ID card, and yet the employee, as previously noted, proceeded to digitize the ID card used in the transaction into the entity's systems. This is supported by the entity's own assertion that a proper identification of the person who disposed of the transaction was not carried out, which indicates truly negligent behavior that could have been easily overcome had the established protocols and precautions been adopted.

On the other hand, it should be noted that the security measures for data processing by the financial entity are focused on the security of banking transactions and indirectly on guaranteeing the fundamental right of affected individuals to the protection of their personal data.

5. Lastly, it is true that the Supreme Court in its ruling of 15/02/2022 stated: "The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that if a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to achieve a specific objective, ensuring the achievement of the proposed result, in this case, guaranteeing the security of personal data and the non-existence of leaks or security breaches.

In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to carry out diligent activity in their implementation and use, aimed at achieving the

expected result with means that can reasonably be classified as suitable and sufficient for its attainment; hence they are referred to as "diligence" or "behavior" obligations.

The difference lies in the liability in each case, as while in an obligation of result one is liable for a harmful result due to a failure of the security system, regardless of its cause and the diligence used. In an obligation of means, it is sufficient to establish technically adequate measures and to implement and use them with reasonable diligence.

In the latter, the sufficiency of the security measures that the responsible party must establish must be related to the state of technology at each moment and the level of protection required concerning the personal data processed, but no result is guaranteed."

However, the Court also confirms that the design of the necessary technical and organizational means is not sufficient, as their correct implementation and appropriate use are also necessary.

The responsibility of the respondent is determined by the security incident highlighted by the claimant, as they are responsible for making decisions aimed at effectively implementing that the technical and organizational measures are appropriate to ensure an adequate level of security relative to the risk.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/26

to ensure the confidentiality of the data, restoring its availability and preventing access to it.

In accordance with the above, it is estimated that the respondent would be presumably responsible for the infringement of the GDPR: the violation of Article 32, an infringement classified in its Article 83.4.a).
VI

1. The respondent alleges the existence of a medial concurrence of infringements due to the application of the provision referred to in Article 29.5 of Law 40/2015, of October 1, whereby only one of the two sanctions should be imposed, specifically, the one related to the infringement of Article 6.1 of the GDPR.

Article 29.5 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, establishes that: "When the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

However, such argumentation cannot be accepted; the specific regulation in the area of data protection, namely the GDPR, establishes in its Article 83.3 that: "3. If a controller or a processor intentionally or negligently violates various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements."

We already indicated in FD IV that the processing of personal data violating the principles and guarantees established in Article 6 of the GDPR is considered a very serious infringement, so the only limit would be established by the amount indicated in Article 83.5 of the GDPR "€20,000,000 at most or, in the case of an undertaking, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount."

2. In its allegations to the Proposal, the respondent insists on the existence of a medial concurrence of infringements; continuing with what has been expressed, it should be noted that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR. This is because the GDPR is a closed and complete system.

The GDPR is a European regulation directly applicable in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation, specifically and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, providing a complete system without gaps that must be understood, interpreted, and integrated absolutely, completely, and integrally, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the

C/ Jorge Juan, 6

www.aepd.es

Protection of Personal Data. The contrary determines the reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or specifies the existing rule related to a possible joint liability (Article 83.3 of the GDPR).

In addition to the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). In this sense, the LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the intended purpose of the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that:

“(2) The principles and rules concerning the protection of individuals with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of individuals.”

And Recital 13 of the GDPR states that:

“(13) In order to ensure a consistent level of protection for individuals throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary to provide legal certainty and transparency to economic operators, including micro-enterprises and small and medium-sized enterprises, and to offer individuals from all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of individuals with regard to the processing of personal data.”

In this system, what is decisive in the GDPR are not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR, combined with the provisions of Article 83 of the GDPR, demonstrate the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR establishes that "Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those provided for in Article 58, paragraph 2, letters a) to h) and j)."

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution of them.

All of this aims to enforce compliance with the GDPR, prevent non-compliance, promote adherence, and ensure that the infringement is not more profitable than compliance.

Therefore, Article 83.1 of the GDPR stipulates that "Each supervisory authority shall ensure that the

imposition of administrative fines in accordance with this Article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive."

Fines must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR. For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - or due to the application of a different legal framework than that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, and the legislator's intent, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms. And this is because there is no legal gap, there is no supplementary application of Article 29 of the LRJSP.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/26

On the other hand, it should be noted that there is no legal gap regarding the application of the concurrent offense. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in case of possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no subsidiary application regarding the LRJSP, which does not contain any provision related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor can the section relating to the concurrent offense be applied for the same reasons.

VII

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or

organizational measures they have implemented pursuant to Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular, whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject."

- In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 6.1 of the GDPR, classified in Article 83.5.a) of the GDPR for which the respondent is responsible, the following factors are considered concurrent as aggravating circumstances:

The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation; the facts revealed affect a basic principle regarding the processing of personal data, such as legitimacy, which the norm penalizes with the utmost severity; it is evident that the claimant's data was used by a third party who was neither the owner nor authorized to carry out the cash withdrawal operation (Article 83.2.a) of the GDPR).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/26

Intentionality or negligence in the infringement. A serious lack of negligence is observed due to the failure to comply with the established procedures, as the identity of the third party disposer was not verified, and there was no proper comparison of both the photograph and the signature on the document presented to ensure they matched the account holder.

Also connected with the degree of diligence that the data controller is obliged to exercise in fulfilling the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited. Although it was issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case we are analyzing. The ruling, after mentioning that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the

degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2, b) of the GDPR).

The investigated entity is one of the large companies within its sector, with a sales volume of more than €1,000,000,000 according to AXESOR data (Article 83.2.k) of the GDPR).

Mitigating circumstances:

Any measures taken by the data controller or processor to mitigate the damages suffered by the affected parties; once the fraud was detected, instructions were issued to prevent such incidents; this is evidenced by the informational alerts sent via email by the Security Officer of the Southern Territorial Directorate to the office where the funds were withdrawn (Article 83.2.c) GDPR).

- In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement classified in Article 83.4.a) and Article 32.1 of the GDPR for which the respondent is held responsible, the following factors are considered concurrent as aggravating circumstances:

Aggravating circumstances:

The nature and severity of the infringement, as we are dealing with the processing of economic data, which affects their solvency, in addition to the damages suffered since, as a result of the entity's negligence, the funds in the account were emptied, benefiting someone who was not the account holder (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

Intentionality or negligence in the infringement. A serious lack of negligence is observed due to the failure to comply with the established procedures, as the identity of the third party disposer was not verified, and there was no proper comparison of both the photograph and the signature on the document presented to ensure they matched the account holder.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/26

account holder. Also connected with the degree of diligence that the data controller is obliged to exercise in compliance with the obligations imposed by data protection regulations is the SAN of 17/10/2007. Although it was issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2, b) of the GDPR).

Previous infringement committed by the data controller or processor; there is recidivism derived from infringements related to the same facts: there are procedures resolved for infringements by the respondent related to Articles 32.1 of the GDPR (PS/362/2021 and PS/420/2021) (Article 83.2, e) of the GDPR).

The investigated entity is one of the large companies within its sector with a sales volume of more than €1,000,000,000 according to AXESOR data (Article 83.2.k) of the GDPR).

The following are mitigating circumstances:

Any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects; once the fraud was detected, instructions were issued to prevent such incidents; this is evidenced by the informational alerts sent via email by the Security Officer of the Southern Territorial Directorate to the office where the funds were withdrawn (Article 83.2.c) GDPR).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the

graduation of the sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on BANCO BILBAO VIZCAYA ARGENTARIA, S.A., with NIF A48265169, for infringement of Articles 6.1 and 32.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR, fines of €50,000 (fifty thousand euros) and €20,000 (twenty thousand euros), respectively.

SECOND: TO NOTIFY this resolution to BANCO BILBAO VIZCAYA ARGENTARIA, S.A.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/26

THIRD: To inform the sanctioned party that they must comply with the imposed sanction once this resolution becomes executive, in accordance with the provisions of art. 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not have knowledge of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/26

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es